KING FAHD UNIVERSITY OF PETROLEUM & MINERALS COLLEGE OF COMPUTER SCIENCES & ENGINEERING

SWE 445 Secure Software Development

Term 252

Phase 1. Software Requirements Specifications

Team F05

Table of content

Table of content 2
Introduction 3
Problem Statement 4
Objectives of the System 5
Scope of the System 6
Part A: Secure Software Requirements 7
1. Confidentiality Requirements 7
2. Integrity Requirements 7
3. Availability Requirements 7
4. Authentication Requirements 8
5. Authorization Requirements 8
6. Accountability Requirements 8
Part B : Actors, Use Cases, and Misuse Case Modeling 9
1. Identify Legitimate Actors 9
2. Identify Normal Use Cases 9
3. Identify Misuse Case Actors 10
4. Identify Misuse Cases 10
5. Use Case and Misuse Case Model Diagram 11
Part C: Mitigation Use Case 12
1. Mitigation Use Cases: 12
2. Updated Use Case diagram 13
Part D 14
1. Normal Use Case Descriptions 14
2. Misuse Case Descriptions 19
3. Mitigation Use Case Descriptions 22

Introduction

Healthcare systems manage highly sensitive data such as patient identity information, medical history, diagnoses, prescriptions, and appointment records. Because this information is private and critical, any healthcare management system must provide strong security controls in addition to normal system functionality.

The proposed system, As-Shifa Secure Healthcare Management System, is intended to manage patient records securely. The system will support registration, medical history management, prescriptions, and appointments while ensuring compliance with privacy and security regulations. This report presents the Phase 1 Software Requirements Specification, including secure software requirements, system actors, use cases, misuse cases, mitigation use cases, and their detailed descriptions.

Problem Statement

The objective of this project is to develop a system for As-Shifa Secure Healthcare Management System. The system aims to securely manage patient records, including:

- Patient registration
- Medical history
- Prescriptions
- Appointments

The system must ensure that medical information remains protected from unauthorized access, tampering, disclosure, and misuse. Since healthcare information is highly sensitive, the system must include proper security features to protect confidentiality, integrity, and availability while allowing only authorized users to perform permitted actions.

Objectives of the System

The main objectives of the system are:

- To provide a secure platform for managing patient records
- To support efficient patient registration and appointment scheduling
- To allow doctors to view and update medical history securely
- To enable prescription creation and verification
- To enforce access control according to user roles
- To maintain records of system activities for accountability and monitoring
- To reduce the risk of data leakage, unauthorized access, and record manipulation

Scope of the System

The system covers the following main functions:

- Patient registration and profile management
- User login and logout
- Appointment booking and management
- Medical history viewing and updating
- Prescription creation and viewing
- User account management
- Audit logging and security monitoring

The system is intended for use by patients, receptionists, doctors, pharmacists, and system administrators. Security mechanisms such as authentication, access control, encryption, and logging are included to protect healthcare information.

Part A: Secure Software Requirements

The As-Shifa Secure Healthcare Management System manages highly sensitive patient information, including medical history, prescriptions, and insurance data. Therefore, security requirements must be considered during the early stages of system development.

Based on the six core concepts of secure software development, confidentiality, integrity, availability, authentication, authorization, and accountability, the following security requirements are identified.

1. Confidentiality Requirements

Confidentiality ensures that sensitive patient information is accessible only to authorized individuals.

- **C1:** The system shall ensure that patient medical records are accessible only to authorized users such as doctors or the patient themselves.
- **C2:** The system shall prevent unauthorized users from viewing sensitive patient information, including medical history and prescriptions.
- **C3:** The system shall require users to log in before accessing any patient-related information.
- **C4:** The system shall ensure that sensitive information such as passwords are not displayed to other users.
- **C5:** The system shall ensure that users can only view the information necessary for their role in the system.

2. Integrity Requirements

Integrity ensures that patient information remains accurate and is not modified without proper authorization.

- **I1:** The system shall allow only authorized healthcare personnel to update patient medical records.
- **I2:** The system shall ensure that patient data entered into the system is validated before being stored.
- **I3:** The system shall prevent unauthorized users from modifying prescriptions, diagnoses, or appointment details.
- **I4:** The system shall ensure that updates to patient information are saved correctly without corrupting existing records.
- **I5:** The system shall maintain consistent patient data when records are updated or modified.

3. Availability Requirements

Availability ensures that authorized users can access the system and patient information whenever it is needed.

- **A1:** The system shall allow authorized users to access patient records when required.
- **A2:** The system shall support multiple users accessing the system at the same time.
- **A3:** The system shall ensure that stored patient information remains available after system restarts.
- **A4:** The system shall allow users to retrieve stored patient records quickly when needed.
- **A5:** The system shall maintain stable operation during normal system usage.

4. Authentication Requirements

Authentication verifies the identity of users before allowing them to access the system.

- **AU1:** The system shall require users to log in using a username and password before accessing system services.
- **AU2:** The system shall ensure that each user has a unique account in the system.
- **AU3:** The system shall verify the correctness of login credentials before granting access.
- **AU4:** The system shall deny system access when incorrect login credentials are provided.
- **AU5:** The system shall allow users to log out securely after completing their tasks.

5. Authorization Requirements

Authorization controls what actions different users are allowed to perform in the system.

- **AR1:** The system shall assign specific roles to users such as patient, doctor, receptionist, and system administrator.
- **AR2:** The system shall allow patients to view their own medical records and appointment details.
- **AR3:** The system shall allow doctors to view and update the medical records of their patients.
- **AR4:** The system shall allow receptionists to manage patient registration and appointment scheduling.
- **AR5:** The system shall restrict users from accessing information or performing actions outside their assigned role.

6. Accountability Requirements

Accountability ensures that user activities within the system can be traced and reviewed when necessary.

- **AC1:** The system shall record user login activities.
- **AC2:** The system shall record when patient records are viewed or updated.
- **AC3:** The system shall maintain activity logs for important system actions.
- **AC4:** The system shall allow system administrators to review system activity logs.
- **AC5:** The system shall prevent regular users from modifying or deleting system activity logs

Part B : Actors, Use Cases, and Misuse Case Modeling

1. Identify Legitimate Actors

These are the authorized users and entities that will interact with the As-Shifa Secure Healthcare Management System to perform standard operations:

- **Patient:** An individual seeking medical care who interacts with the system to register, book appointments, view records, pay bills, and attend telemedicine consultations.

- **Doctor/Physician:** A medical professional responsible for reviewing patient records, updating medical histories, conducting remote consultations, and issuing prescriptions.

- **Receptionist/Admin Staff:** Hospital staff handling schedules, billing processing, and general reception duties.

- **System Administrator:** The technical IT staff responsible for managing staff profiles, system availability, and role-based access controls.

2. Identify Normal Use Cases

Based on the legitimate actors, the core functionalities of the system include:

- **UC-01: Register Patient Profile:** Allowing a patient or receptionist to create and update a user profile.
- **UC-02: Manage Appointments:** Scheduling, rescheduling, or canceling doctor visits.
- **UC-03: View Medical History:** Allowing doctors and patients to read historical medical records securely.
- **UC-04: Update Medical History:** Allowing doctors to modify and append data to patient records.
- **UC-05: Issue Prescriptions:** Doctors securely assigning medications to a patient's record.
- **UC-06: Process Billing:** Allowing receptionists to invoice patients and patients to securely pay medical fees.
- **UC-07: Telemedicine Consult:** A secure video-conferencing module connecting Doctors and Patients remotely.
- **UC-08: Manage Staff Profiles:** System Admins configuring new internal employee accounts and permissions.

3. Identify Misuse Case Actors

These are the malicious entities (threat agents) whose goal is to subvert the system, steal data, or disrupt services:

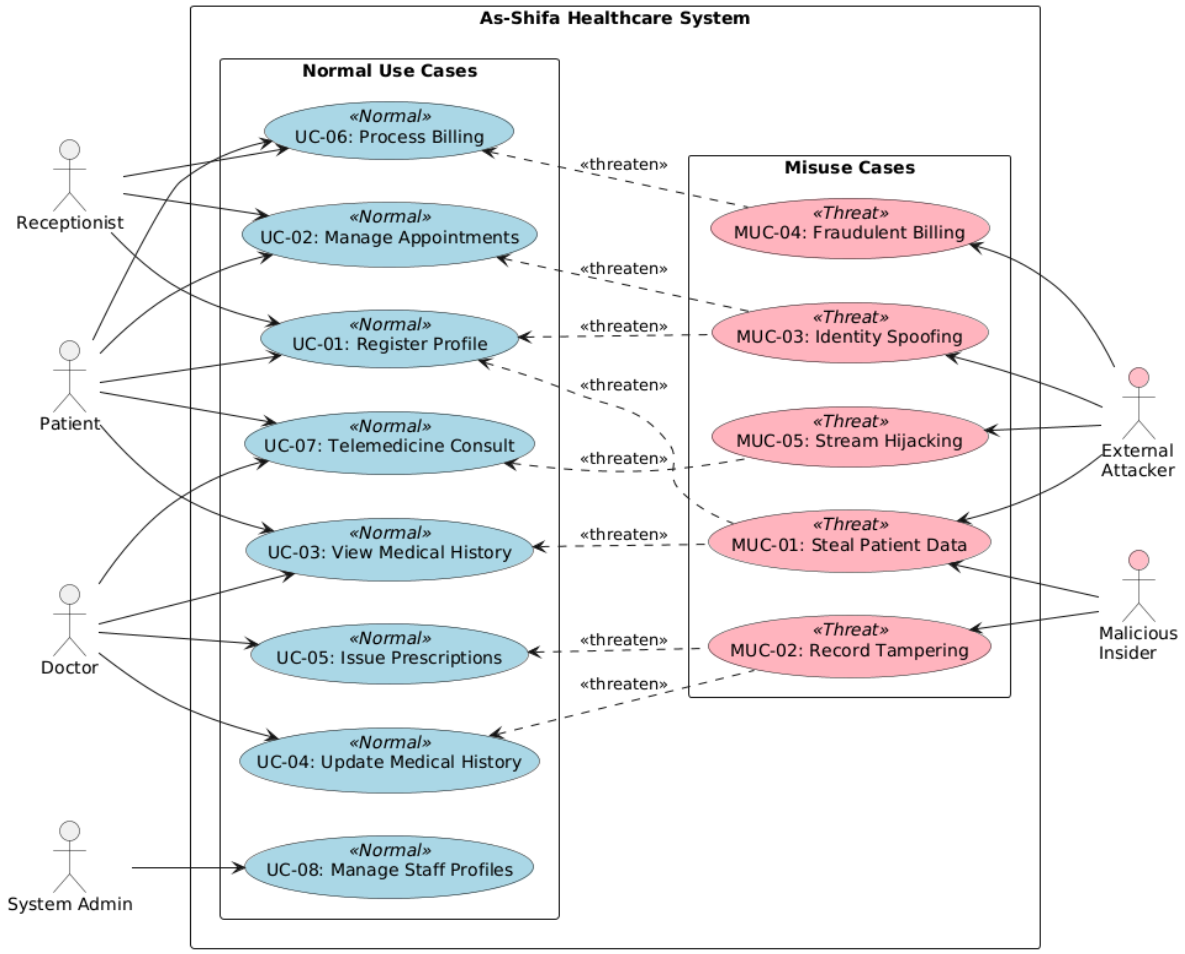
- **External Hacker (Attacker):** An unauthorized outside individual attempting to breach the system for financial gain (e.g., selling medical data, intercepting payments).
- **Malicious Insider:** An authorized user (such as a disgruntled employee or a corrupt staff member) who abuses their privileges to tamper with restricted data.

4. Identify Misuse Cases

These are the malicious actions performed by the misuse actors that threaten the standard use cases:

- **MUC-01: Steal Patient Data (Data Exfiltration):** An attacker attempts to bypass access controls to download highly sensitive medical histories.
- **MUC-02: Record Tampering:** A malicious insider modifies a patient's medical history or prescriptions, compromising data integrity.
- **MUC-03: Identity Spoofing:** An attacker impersonates a Doctor or Patient by stealing their login credentials to abuse the system.
- **MUC-04: Fraudulent Billing (Payment Interception):** An attacker intercepts the billing system to redirect patient payments to unauthorized offshore accounts.
- **MUC-05: Stream Hijacking:** An attacker eavesdrops on or disrupts a confidential Telemedicine Consultation by exploiting unencrypted video feeds.

5. Use Case and Misuse Case Model Diagram

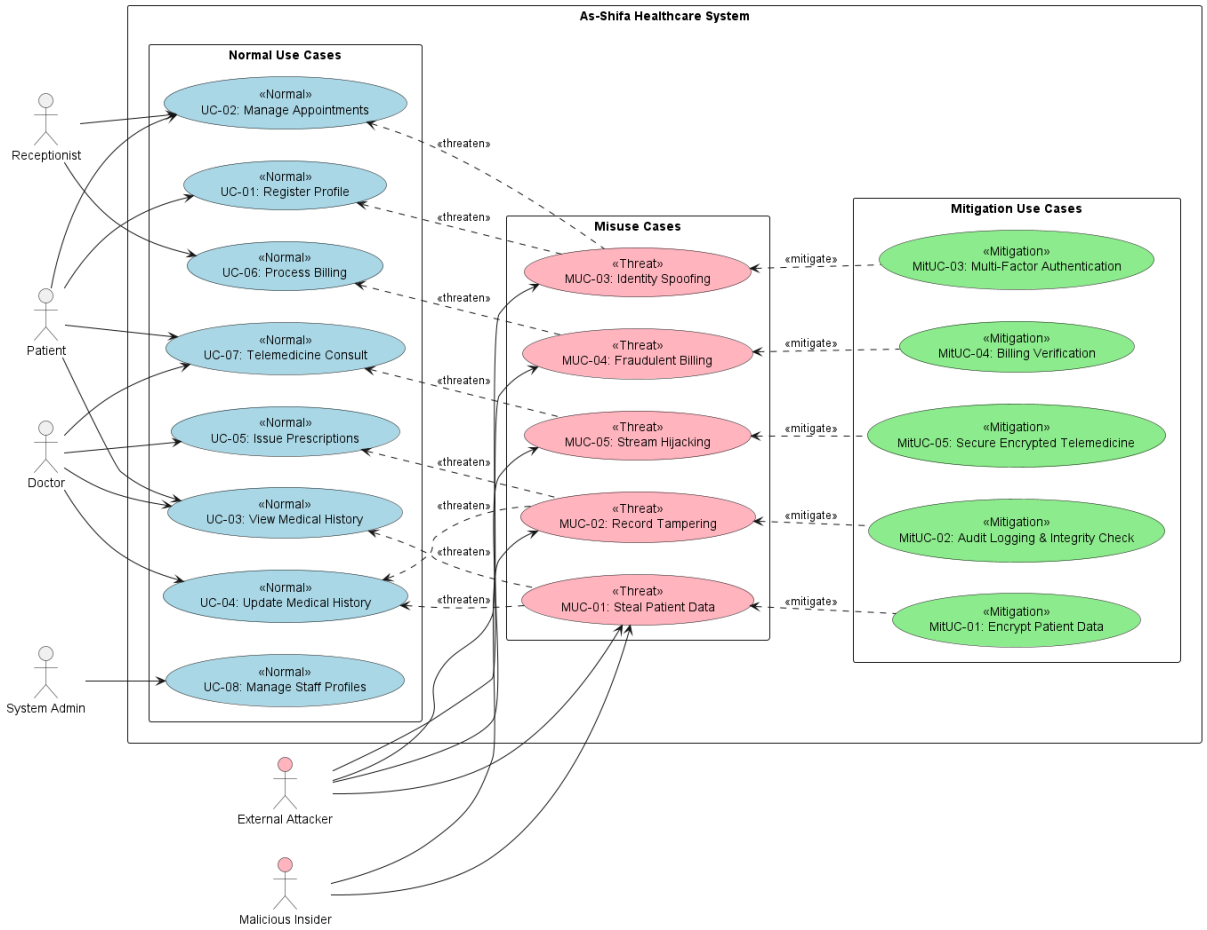


Part C: Mitigation Use Case

1. Mitigation Use Cases:

- **MitUC-01: Encrypt Patient Data:**
  Encrypts the patient's data before storing them in the database or transmitting them. By encrypting the data, we prevent the attacker from understanding the data then by that we prevent data theft cases.
- **MitUC-02: Audit Logging & Integrity Check:**
  The system records all important activities such as record updates, prescription changes, and billing operations in secure audit logs.
  These logs help detect and investigate unauthorized modifications by keeping a record of all the actions applied.
- **MitUC-03: Multi-Factor Authentication:**
  This applies more than one method to authenticate the user such as password and one time verification code.
  This ensures secure logging.
- **MitUC-04: Billing Verification:**
  The system verifies billing transactions before they are finalized to ensure accuracy and prevent fraudulent billing activities.
- **MitUC-05: Secure Encrypted Telemedicine:**
  The system secures telemedicine consultations using encrypted communication channels to prevent unauthorized interception or hijacking of the video stream.

2. Updated Use Case diagram



Part D

1. Normal Use Case Descriptions

UC-01: Register Patient Profile	
Description:	This use case allows a patient or receptionist to create a new patient profile in the system. The profile includes personal details, contact information, and a unique patient identifier.
Actors:	Patient, Receptionist.
Main Flow:	1. Patient or receptionist selects Register Patient. 2. The system displays the registration form. 3. User enters required information (name, DOB, contact info). 4. System validates the entered information. 5. System generates a unique patient ID. 6. System stores the patient profile securely. 7. Confirmation message is displayed.
Alternative(s):	● If required information is missing → system prompts user to complete fields. ● If patient already exists → system notifies duplicate record.

UC-02: Manage Appointments	
Description:	Allows patients or receptionists to schedule, reschedule, or cancel appointments with doctors.
Actors:	Patient, Receptionist.
Main Flow:	1. User selects Manage Appointments. 2. System displays available doctors and time slots. 3. User selects a doctor and preferred time. 4. System verifies availability. 5. Appointment is scheduled. 6. System sends confirmation notification.
Alternative(s):	● If time slot unavailable → system suggests alternative slots. ● If appointment cancelled → system updates schedule.

UC-03: View Medical History	
Description:	Allows doctors and patients to securely view stored medical records including diagnosis history and treatment records.
Actors:	Doctor, Patient.
Main Flow:	1. User logs into the system. 2. User selects View Medical History. 3. System verifies authorization. 4. System retrieves patient medical record. 5. Medical history is displayed.
Alternative(s):	● Unauthorized user attempts access → system denies request.

UC-04: Update Medical History	
Description:	Allows doctors to add or modify medical information such as diagnosis, test results, or treatment plans.
Actors:	Doctor.
Main Flow:	1. Doctor logs into system. 2. Doctor selects patient record. 3. Doctor selects Update Medical History. 4. Doctor enters new medical information. 5. System validates input. 6. System updates patient record. 7. Update is saved in database.
Alternative(s):	● Invalid data entered → system rejects input.

UC-05: Issue Prescriptions	
Description:	Doctors issue prescriptions for patients after consultation.
Actors:	Doctor.
Main Flow:	1. Doctor opens patient record. 2. Doctor selects Issue Prescription. 3. Doctor enters medication details. 4. System verifies prescription format. 5. Prescription is stored in database. 6. Patient can access prescription.
Alternative(s):	● Invalid medication data → system requests correction.

UC-06: Process Billing	
Description:	Handles patient billing and payment processing for medical services.
Actors:	Receptionist, Patient.
Main Flow:	1. Receptionist opens billing module. 2. System retrieves patient visit details. 3. System calculates total charges. 4. Patient selects payment method. 5. System processes payment. 6. Receipt is generated.
Alternative(s):	● Payment failure → system notifies user.

UC-07: Telemedicine Consultation	
Description:	Allows doctors and patients to communicate remotely using a secure video session.
Actors:	Doctor, Patient.
Main Flow:	1. Patient schedules telemedicine consultation. 2. Doctor accepts appointment. 3. Both participants join video session. 4. System establishes secure connection. 5. Consultation takes place. 6. Session ends.
Alternative(s):	● Connection failure → session reconnect attempted.

UC-08: Manage Staff Profiles	
Description:	System administrators manage staff accounts and permissions.
Actors:	System Administrator.
Main Flow:	1. Admin logs into system. 2. Admin selects Manage Staff Profiles. 3. Admin creates or updates staff accounts. 4. Admin assigns roles and permissions. 5. System stores updated information.
Alternative(s):	● Duplicate staff account detected → system alerts admin.

2. Misuse Case Descriptions

MUC-01: Steal Patient Data	
Description:	An attacker attempts to gain unauthorized access to sensitive patient information such as medical history or prescriptions.
Actors:	External Hacker.
Main Flow:	1. Attacker attempts unauthorized login. 2. Attacker tries to bypass authentication. 3. Attacker accesses database records. 4. Patient data is extracted.
Alternative(s):	● System detects abnormal login activity.
Mitigation Points	● Multi-Factor Authentication ● Data Encryption ● Access Control

MUC-02: Record Tampering	
Description:	A malicious insider modifies patient medical records or prescriptions.
Actors:	Malicious Insider.
Main Flow:	1. Insider logs into system. 2. Insider accesses patient record. 3. Insider modifies medical history. 4. Modified record is stored.
Alternative(s):	● Suspicious modification detected in logs.
Mitigation Points	● Audit Logging ● Integrity Checks ● Role-based access control

MUC-03: Identity Spoofing	
Description:	An attacker impersonates another user (doctor or patient) by stealing login credentials.
Actors:	External Hacker.
Main Flow:	1. Attacker obtains user credentials. 2. Attacker logs into system. 3. Attacker performs actions as legitimate user.
Alternative(s):	● Suspicious login location detected.
Mitigation Points	● Multi-Factor Authentication ● Login monitoring

MUC-04: Fraudulent Billing	
Description:	An attacker manipulates billing transactions to redirect payments.
Actors:	External Hacker.
Main Flow:	1. Attacker intercepts billing transaction. 2. Payment destination modified. 3. Funds redirected to attacker account.
Alternative(s):	● Billing verification detects mismatch.
Mitigation Points	● Billing Verification ● Transaction validation

MUC-05: Stream Hijacking	
Description:	An attacker intercepts telemedicine video sessions.
Actors:	External Hacker.
Main Flow:	1. Attacker intercepts video stream. 2. Attacker accesses consultation session. 3. Confidential conversation exposed.
Alternative(s):	● System detects connection anomaly.
Mitigation Points	● Secure encrypted telemedicine communication

3. Mitigation Use Case Descriptions

MitUC-01: Encrypt Patient Data	
Description:	The system encrypts sensitive patient information during storage and transmission to protect confidentiality.
Actors:	System.
Main Flow:	1. Patient data is entered. 2. System encrypts the data. 3. Data is stored in encrypted format. 4. Authorized users decrypt when accessing.

MitUC-02: Audit Logging and Integrity Check	
Description:	The system records all critical system activities to monitor suspicious actions.
Actors:	System Administrator.
Main Flow:	1. User performs an action. 2. System records action in audit log. 3. Admin reviews logs for suspicious behavior.

MitUC-03: Multi-Factor Authentication	
Description:	Users must verify their identity using multiple authentication factors.
Actors:	Patient, Doctor, Admin.
Main Flow:	1. User enters username and password. 2. System verifies credentials. 3. System sends OTP to registered device. 4. User enters OTP. 5. Access granted.
Alternatives:	● Incorrect OTP → access denied.

MitUC-04: Billing Verification	
Description:	Billing transactions are verified before final processing.
Actors:	Receptionist, System.
Main Flow:	1. Billing transaction initiated. 2. System verifies payment details. 3. System validates payment destination. 4. Transaction approved.

MitUC-05: Secure Encrypted Telemedicine	
Description:	Telemedicine consultations are protected using encrypted communication channels.
Actors:	Doctor, Patient.
Main Flow:	1. Consultation session initiated. 2. System establishes encrypted channel. 3. Video consultation proceeds securely. 4. Session ends securely.